Plan de monitoreo y auditoría

CloudWatch, CloudTrail y AWS Config · Pre-entrega 7 · EduStart · Lucas Federico Scarpitta

Este plan retoma la arquitectura de las Pre-entregas 3 a 6: ALB, Auto Scaling Group con instancias EC2 t3.micro en subnets privadas, RDS MySQL Multi-AZ, un NAT Gateway por zona, S3 y CloudFront. Define cómo se observa la plataforma, cómo se avisa cuando algo falla y cómo queda registrado cada cambio. Todo se crea en `us-east-1`, la región de la plataforma y la única donde existen las métricas de facturación y de CloudFront.

Servicios y métricas críticas

A partir de los puntos de fallo del diagrama de red se eligieron seis grupos de recursos, cada uno con al menos dos métricas críticas.

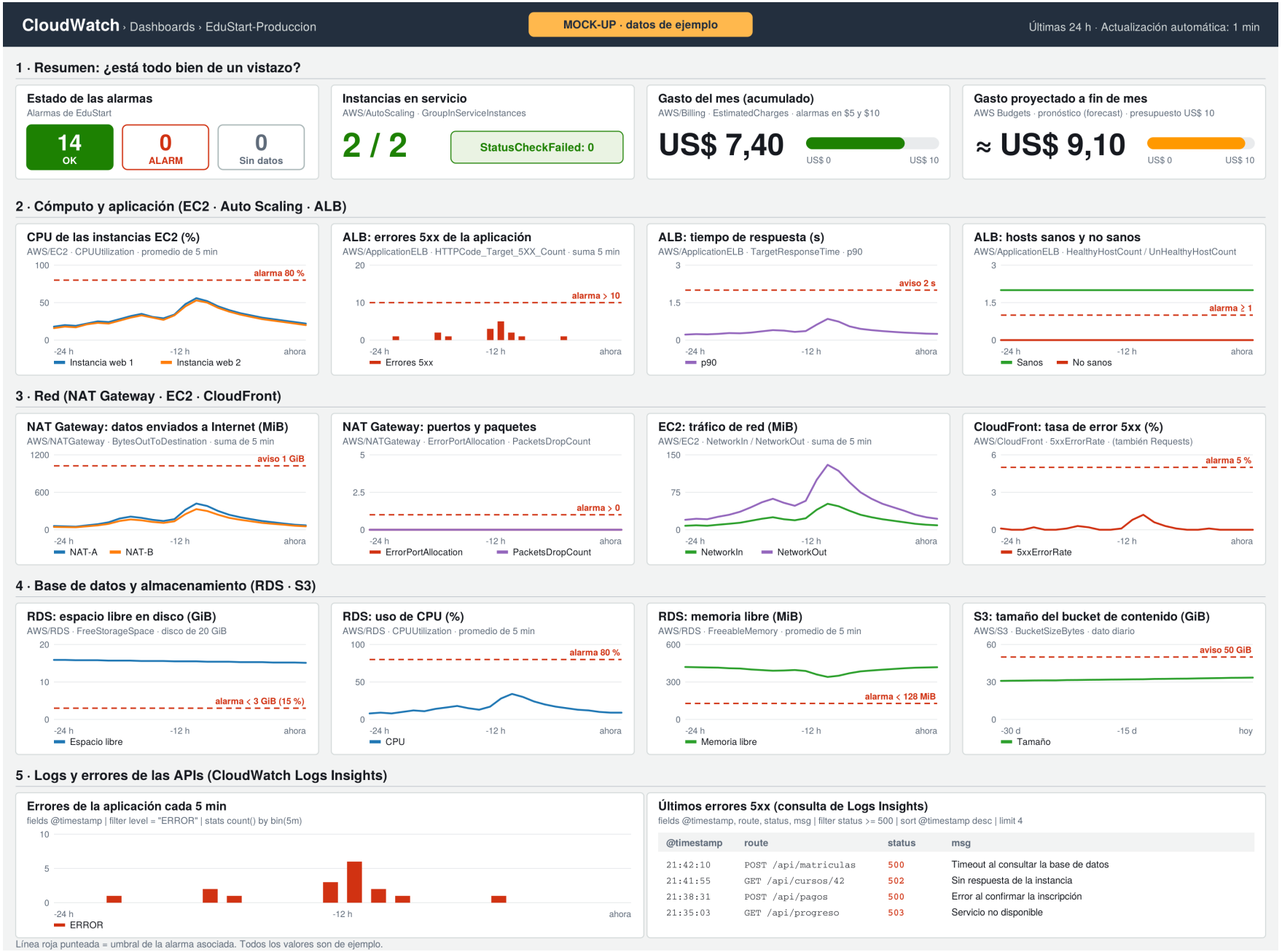
Servicio	Punto de fallo en el diagrama	Métricas críticas (namespace)
EC2 y Auto Scaling Group	Instancias saturadas o caídas; el grupo queda con menos de 2 instancias.	`CPUUtilization`, `StatusCheckFailed`, `NetworkIn` y `NetworkOut` (AWS/EC2); `GroupInServiceInstances` (AWS/AutoScaling)
Application Load Balancer	Errores de la aplicación o instancias que no pasan el health check.	`HTTPCode_Target_5XX_Count`, `UnHealthyHostCount`, `TargetResponseTime` (AWS/ApplicationELB)
RDS MySQL	Disco lleno, CPU o memoria agotadas.	`FreeStorageSpace`, `CPUUtilization`, `FreeableMemory` (AWS/RDS)
NAT Gateway	Agotamiento de puertos o tráfico de salida inesperado, que además cuesta dinero.	`ErrorPortAllocation`, `BytesOutToDestination` (AWS/NATGateway)
CloudFront y S3	Errores 5xx para el público; crecimiento descontrolado del almacenamiento.	`5xxErrorRate` (AWS/CloudFront); `BucketSizeBytes` (AWS/S3)
Facturación	Gasto fuera del presupuesto.	`EstimatedCharges` (AWS/Billing)

Tres detalles que suelen pasarse por alto: las métricas estándar de EC2 no incluyen memoria ni espacio en el disco del sistema operativo (para verlas hace falta instalar el CloudWatch Agent); `GroupInServiceInstances` solo aparece si se habilitan las métricas de grupo del Auto Scaling; y las métricas de facturación exigen activar la opción de alertas de facturación en la cuenta.

1. Diseño del dashboard

El panel se llama `EduStart-Produccion`, tiene un rango de 24 horas con actualización cada minuto y se lee de arriba hacia abajo: primero responde a la pregunta «¿está todo bien?» y, si no lo está, el orden de las filas indica dónde mirar. El mock-up está en la página siguiente y, después, se explica fila por fila.

1.1 Mock-up del dashboard



1.2 Orden de lectura y widgets

Fila	Qué se ve	Widgets
1 · Resumen	Lo primero que se mira: salud, alarmas y gasto.	Estado de las alarmas; instancias en servicio (2 de 2); gasto acumulado del mes; gasto proyectado.
2 · Cómputo y aplicación	Si las instancias aguantan y si la aplicación responde.	Líneas de CPU de cada EC2; errores 5xx; tiempo de respuesta p90; hosts sanos y no sanos del ALB.
3 · Red	Si el tráfico fluye y cuánto sale a Internet.	Bytes enviados por cada NAT Gateway; puertos y paquetes descartados; NetworkIn y NetworkOut; errores 5xx de CloudFront.
4 · Base de datos y almacenamiento	Cuánto espacio y capacidad queda.	Espacio libre de RDS (con la línea de alarma en 3 GiB); CPU y memoria libre de RDS; tamaño del bucket de S3.
5 · Logs y errores de las APIs	Qué falla y dónde, a partir de los logs de la aplicación.	Gráfico de errores cada 5 minutos y tabla con los últimos errores 5xx, ambos con CloudWatch Logs Insights.

Gasto proyectado. CloudWatch solo mide el gasto acumulado del mes (`EstimatedCharges`). El pronóstico de fin de mes lo calcula AWS Budgets, por lo que el panel lo muestra con un widget de texto con el valor y el enlace al presupuesto, y se avisa con un presupuesto de US$ 10 que alerta cuando el pronóstico supera el 100 %.

Errores de las APIs. La aplicación escribe logs en formato JSON en el grupo `/edustart/app` mediante el CloudWatch Agent. Los dos widgets de la fila 5 usan estas consultas:

```
fields @timestamp
| filter level = "ERROR"
| stats count() by bin(5m)

fields @timestamp, route, status, msg
| filter status >= 500
| sort @timestamp desc
| limit 20
```

2. Matriz de alarmas

Las alarmas son preventivas: avisan antes de que el servicio caiga. Se dividen en **críticas**, que exigen acción inmediata, y **avisos**, que se revisan durante el día. Todas usan períodos de 5 minutos o más y exigen varios períodos seguidos para ignorar picos momentáneos.

Servicio	Métrica	Condición (umbral)	Período de evaluación	Acción de alerta
EC2 / ASG	`CPUUtilization` promedio	> 80 %	5 min · 3 períodos seguidos	Email (avisos)
EC2	`StatusCheckFailed` máximo	≥ 1	5 min · 2 períodos seguidos	Email (críticas)
Auto Scaling	`GroupInServiceInstances` mínimo	< 2	5 min · 2 períodos seguidos	Email (críticas)
ALB	`HTTPCode_Target_5XX_Count` suma	> 10	5 min · 2 de 3 períodos	Email (críticas)
ALB	`UnHealthyHostCount` máximo	≥ 1	5 min · 2 períodos seguidos	Email (críticas)
ALB	`TargetResponseTime` percentil 90	> 2 s	5 min · 3 períodos seguidos	Email (avisos)

Servicio	Métrica	Condición (umbral)	Período de evaluación	Acción de alerta
RDS	`FreeStorageSpace` mínimo	< 3 GiB (15 % de 20 GiB)	5 min · 2 períodos seguidos	Email (críticas)
RDS	`CPUUtilization` promedio	> 80 %	5 min · 3 períodos seguidos	Email (avisos)
RDS	`FreeableMemory` mínimo	< 128 MiB	5 min · 3 períodos seguidos	Email (avisos)
NAT Gateway	`ErrorPortAllocation` suma	> 0	5 min · 2 períodos seguidos	Email (avisos)
NAT Gateway	`BytesOutToDestination` suma	> 1 GiB (valor inicial)	5 min · 2 períodos seguidos	Email (avisos)
CloudFront	`5xxErrorRate` promedio	> 5 %	5 min · 2 períodos seguidos	Email (críticas)
S3	`BucketSizeBytes` promedio	> 50 GiB (valor inicial)	1 día · 1 período	Email (avisos)
Facturación	`EstimatedCharges` máximo	> US$ 5	6 horas · 1 período	Email (avisos)
Facturación	`EstimatedCharges` máximo	> US$ 10	6 horas · 1 período	Email (críticas)

2.1 Notificaciones con Amazon SNS

Tópico SNS	Para qué se usa	Suscripción
`edustart-alertas-criticas`	Alarmas críticas de la tabla: requieren acción inmediata.	Email a admin@example.com
`edustart-alertas-avisos`	Avisos de capacidad, rendimiento y costo: se revisan durante el día.	Email a admin@example.com
`edustart-alertas-seguridad`	Cambios de infraestructura y de cumplimiento detectados por CloudTrail y AWS Config (sección 3).	Email a admin@example.com

2.2 Reglas de diseño contra las alarmas ruidosas

- **Períodos de 5 minutos o más** y «N períodos seguidos» antes de disparar, para que un pico de un minuto no genere un aviso.
- **Datos faltantes:** las métricas que no emiten datos cuando no hay eventos (como los errores 5xx) se configuran para tratar los datos faltantes como «no incumplidos», así no aparecen alarmas en estado de datos insuficientes.
- **Dos niveles de severidad:** si todo llegara al mismo tópico, los avisos taparían las críticas.
- **Umbrales iniciales:** son supuestos de diseño. Se revisan tras dos semanas con datos reales y se ajustan.
- **Confirmar las suscripciones:** SNS envía un correo de confirmación a cada dirección; sin confirmarlo no llega ninguna alerta.
- **Facturación:** las alarmas se crean en us-east-1 y requieren activar «Receive CloudWatch Billing Alerts» en las preferencias de facturación. La métrica se actualiza cada unas 6 horas, por eso el período es de 6 horas.

3. Configuración de auditoría

CloudTrail y AWS Config se complementan: CloudTrail responde **quién hizo qué y cuándo** (las llamadas a la API), y AWS Config responde **cómo está configurado cada recurso**, cómo cambió con el tiempo y si cumple las reglas. Si Config detecta un Security Group abierto, CloudTrail dice quién lo abrió.

3.1 AWS CloudTrail

Parámetro	Valor
Trail	`edustart-trail`, con alcance a todas las regiones de la cuenta.
Eventos registrados	Eventos de administración, de lectura y de escritura. Los eventos de datos de S3 quedan desactivados al inicio por costo.
Destino	Bucket privado `edustart-auditoria-prod-use1` (prefijo `cloudtrail/`), con Block Public Access y cifrado SSE-S3.
Integridad	Validación de los archivos de log activada: permite detectar si alguien alteró un registro.
Consulta rápida	Envío a CloudWatch Logs (grupo `/edustart/cloudtrail`) y el historial de eventos de la consola, con 90 días y sin costo.
Retención	Mismo criterio que los backups de la Pre-entrega 4: 90 días en Standard, luego Glacier Flexible Retrieval y eliminación a los 730 días.

3.2 Cómo rastrear quién modificó un Security Group

Cada cambio en los Security Groups del módulo anterior (`SG-ALB`, `SG-Web-Servers` y `SG-RDS`) queda registrado como un evento de la API de EC2: `AuthorizeSecurityGroupIngress`, `RevokeSecurityGroupIngress`, `AuthorizeSecurityGroupEgress`, `RevokeSecurityGroupEgress`, `ModifySecurityGroupRules`, `CreateSecurityGroup` y `DeleteSecurityGroup`. Cada registro dice **quién** (`userIdentity`: usuario o rol y su ARN), **cuándo** (`eventTime`), **desde dónde** (`sourceIPAddress`), **qué cambió** (`requestParameters`: el ID del grupo y las reglas) y si funcionó (`errorCode`). Para investigar, se filtra el historial de eventos por nombre de evento o por el ID del grupo; para períodos largos se consulta el bucket con Amazon Athena.

Para enterarse en casi tiempo real, una regla de Amazon EventBridge envía al tópico `edustart-alertas-seguridad` los cambios críticos de red:

```
{
  "source": ["aws.ec2"],
  "detail-type": ["AWS API Call via CloudTrail"],
  "detail": {
    "eventSource": ["ec2.amazonaws.com"],
    "eventName": [
      "AuthorizeSecurityGroupIngress", "RevokeSecurityGroupIngress",
      "DeleteVpc", "DeleteSubnet", "DeleteNatGateway",
      "DetachInternetGateway", "DeleteInternetGateway",
      "DeleteRoute", "ReplaceRoute", "DeleteRouteTable",
      "ReplaceNetworkAclEntry", "DeleteNetworkAclEntry"
    ]
  }
}
```

3.3 Eventos de CloudTrail que alertan un cambio crítico

Evento de CloudTrail	Qué significa para la plataforma	Reacción
`DeleteVpc`	Se elimina la VPC completa.	Alerta inmediata; verificar quién y por qué.
`DeleteSubnet`	Se elimina una subnet pública o privada.	Alerta inmediata.
`DeleteNatGateway`	Las subnets privadas pierden la salida a Internet.	Alerta inmediata.
`DetachInternetGateway` / `DeleteInternetGateway`	El ALB deja de ser alcanzable desde Internet.	Alerta inmediata.
`DeleteRoute` / `ReplaceRoute`	Cambia el camino que sigue el tráfico.	Alerta; revisar la tabla de ruteo.
`AuthorizeSecurityGroupIngress`	Se abre un puerto o un origen nuevo.	Alerta; revisar si el origen es 0.0.0.0/0.
`ReplaceNetworkAclEntry` / `DeleteNetworkAclEntry`	Cambia una regla de una NACL.	Alerta; revisar la regla.
`StopLogging` / `DeleteTrail`	Alguien apaga la auditoría.	Alerta inmediata (regla aparte, origen aws.cloudtrail).
`ConsoleLogin` del usuario root	Se usa la cuenta raíz.	Alerta inmediata (regla aparte).

3.4 AWS Config

Parámetro	Valor
Grabador	Registra todos los tipos de recursos soportados de la región y los recursos globales (IAM).
Entrega	Bucket `edustart-auditoria-prod-use1` (prefijo `config/`) y tópico `edustart-alertas-seguridad`.
Reglas	Reglas administradas por AWS (managed rules), evaluadas cuando cambia la configuración de un recurso.
Aviso	Regla de EventBridge sobre «Config Rules Compliance Change» con resultado `NON_COMPLIANT`, hacia el tópico de seguridad.
Remediación	Manual al inicio. Cuando las reglas estén probadas, remediación automática con SSM Automation para S3.
Costo	AWS Config cobra por cada elemento de configuración registrado y por cada evaluación de regla; por eso se empieza con cinco reglas y se amplía solo si hace falta.

Regla (identificador)	Qué verifica	Por qué en EduStart
s3-bucket-public-read-prohibited `S3_BUCKET_PUBLIC_READ_PROHIBITED` y **s3-bucket-public-write-prohibited**	Que ningún bucket permita lectura ni escritura pública.	Los tres buckets son privados (Pre-entrega 4); el contenido sale solo por CloudFront.
restricted-ssh `INCOMING_SSH_DISABLED`	Que ningún Security Group permita SSH (puerto 22) desde 0.0.0.0/0.	SG-Web-Servers solo acepta tráfico del SG-ALB; no debe quedar un acceso remoto abierto.
rds-instance-public-access-check `RDS_INSTANCE_PUBLIC_ACCESS_CHECK`	Que la instancia RDS no sea accesible públicamente.	La base vive en subnets privadas y solo la alcanza SG-Web-Servers (Pre-entregas 5 y 6).
Adicional: **encrypted-volumes** `ENCRYPTED_VOLUMES`	Que los volúmenes EBS estén cifrados.	Los volúmenes gp3 de las EC2 se definieron cifrados (Pre-entrega 4).
Adicional: **rds-multi-az-support** `RDS_MULTI_AZ_SUPPORT`	Que RDS esté desplegada en Multi-AZ.	Garantiza que la alta disponibilidad entre zonas no se pierda por un cambio.